

The AI Governance Baseline

7 Controls Every CTO Should Have Before Agents Go to Production

Elliot Betancourt

Most agent governance failures aren't technical — they're process gaps. These 7 controls represent the minimum viable governance layer for any production AI system. Each one has a clear green/yellow/red scoring so you know exactly where you stand.

1 Identity & Authorization

- Unique identity per agent, scoped to minimum required access
- Shared credentials or over-scoped service accounts
- No agent-specific credentials — using admin access

Why it matters: Shared credentials make breaches untraceable and revocation impossible.

2 Audit Trail

- Structured logs: inputs, reasoning, outputs, tool calls
- Partial logging — outputs captured but not reasoning
- No audit trail — agents are a black box

Why it matters: Without audit trails you can't debug failures or prove compliance.

3 Rate Limiting & Cost Controls

- Enforced budget caps with alerts at 50%, 80%, 100%
- Soft limits — monitoring exists but no hard stops
- No spend limits — agent can run indefinitely

Why it matters: Runaway agents are a production incident waiting to happen.

4 Rollback & Kill Switch

- One-command kill switch, reversible actions logged
- Can disable agents but cannot reverse their actions
- No kill switch — stopping agents requires code deploys

Why it matters: Production means something will go wrong. Rollback speed is the metric.

5 Escalation Protocol

- Explicit uncertainty thresholds trigger human escalation
- Agents can flag for review but default to proceeding
- Agents make all decisions without escalation paths

Why it matters: Agents confident in wrong answers are worse than uncertain ones.

6 Monitoring & Drift Detection

- Output quality metrics tracked weekly with drift alerts
- Error rate monitored but quality degradation not tracked
- No monitoring beyond uptime

Why it matters: Agents degrade. Monitoring outputs is infrastructure, not nice-to-have.

7 Access Scope Review

- Quarterly access review, unused permissions pruned
- Permissions set at launch, never reviewed again
- No access review process exists

Why it matters: Scope creep happens silently. Scheduled reviews catch it before incidents do.

SCORING GUIDE



7 Green:

Production-ready governance. Ship it.



Any Yellow:

Acceptable risk with active monitoring.



Any Red:

Fix before your agents touch production data.



Multiple Red:

Pause. Governance is your next sprint.

Governance isn't overhead. It's what separates the CTOs who scale agents from the ones who explain incidents to the board.